

Consideraciones técnicas sobre protección de datos en UNI+

Lectura preliminar del plugin local_unimas

1. Introducción

Este documento es un aporte preliminar para la discusión del equipo de UNI+. Ofrece una primera lectura técnica y conceptual sobre aspectos de protección de datos en el plugin local_unimas, tomando como referencia la Ley 18.331 y el Decreto 64/020 (Uruguay) y la Ley 25.326 y normativa complementaria de la AAIP (Argentina). No constituye una auditoría formal ni un dictamen jurídico: su propósito es facilitar el diálogo interdisciplinario y orientar la definición de un eventual piloto.

Cabe señalar que las observaciones siguientes son habituales en sistemas en etapa temprana de desarrollo, y forman parte del proceso normal de maduración técnica e institucional de un proyecto de estas características.

2. Resumen ejecutivo

UNI+ es un plugin para Moodle que se apoya en modelos de lenguaje (LLM) externos o locales para generar recomendaciones pedagógicas a partir de información académica y contextual de los estudiantes, tanto a nivel de cohorte como individual.

El análisis sugiere que el diseño actual podría sostener un piloto controlado si previamente se abordan algunos ajustes en seguridad, minimización y gobierno de los datos. Para un despliegue institucional ampliado, sería recomendable un trabajo adicional de fortalecimiento técnico y documentación. La cuestión central no es el uso de IA en sí mismo, sino cómo se gestionan los datos en el flujo actual.

Aspectos a considerar

- Minimización: el flujo individual transmite información que excede lo necesario para la finalidad declarada.
- Permisos: la configuración global del plugin (incluida la API key) puede modificarse con permisos a nivel de curso.
- Salida HTTP: las llamadas no usan el cliente nativo de Moodle, lo que limita el control sobre destinos y proxy institucional.
- Transferencias internacionales: el envío a proveedores externos podría requerir salvaguardas contractuales y técnicas.
- Retención: las tablas internas conservan información sin política de expiración automática.

Fortalezas a destacar

- Arquitectura modular y portable: el plugin admite endpoints OpenAI-compatibles, lo que abre la posibilidad de operar sobre un gateway institucional o un modelo local (por ejemplo, Ollama). Esta característica facilita avanzar hacia un esquema más alineado con los principios de protección de datos.
- Llamada al LLM del lado servidor: la integración no expone la API key en el navegador, lo que es técnicamente preferible a una integración desde el frontend.

Conclusión preliminar: un piloto cerrado y acotado parecería viable con los ajustes prioritarios que se detallan más adelante. Un despliegue institucional amplio requeriría un trabajo conjunto de las áreas técnica, legal y académica.

3. Funcionamiento del sistema

UNI+ se integra a Moodle como plugin local. Al renderizarse el panel principal, el plugin construye indicadores académicos y, si existe una API key configurada y la caché interna no está vigente, puede iniciar una llamada al proveedor de IA sin intervención explícita del docente. Este comportamiento es relevante desde la perspectiva de finalidad y transparencia.

Flujo de datos resumido

- El docente accede al panel del plugin dentro de Moodle.
- El servidor consulta la base de Moodle para construir indicadores por estudiante.
- Los datos se envían al proveedor de IA mediante HTTPS desde el servidor.
- La respuesta JSON se almacena en tablas internas (caché, contexto, acciones) y se muestra al docente.
- El navegador carga adicionalmente la librería SheetJS desde un CDN externo.

El plugin admite distintos proveedores (OpenAI, Anthropic, Gemini, DeepSeek, Ollama u otros endpoints compatibles) y permite configurar un endpoint arbitrario. Esto habilita la posibilidad de utilizar infraestructura local o institucional, aunque también amplía la superficie de configuración a controlar.

4. Tipos de datos tratados

La siguiente clasificación es orientativa y se desprende del análisis del código. Algunas categorías podrían ser transmitidas a proveedores externos en el flujo actual.

Categoría	Ejemplos identificados	¿Sale al LLM?	Lectura preliminar
Identificables directos	UID interno, nombre, correo electrónico	Sí	Datos personales en sentido pleno
Pseudonimizados débiles	Identificadores tipo “E-<id>” usados en la interfaz	UID real viaja en paralelo	No alcanzaría disociación efectiva
Derivados / perfilados	Índice de éxito, delta, nivel, componentes (I_A, I_R, I_E), historial	Sí	Datos personales atribuibles al estudiante
Contextuales pedagógicos	Acción previa, nota docente, días transcurridos, historial	Sí (flujo individual)	Posible impacto reputacional o académico
Texto libre	Campo “context_text” proveniente de encuestas o cargas masivas	Sí	Riesgo de incluir datos sensibles
Inferencias de IA	Resúmenes, reportes, clasificación de prioridad	Se almacenan localmente	Constituyen perfilado del estudiante

Dos observaciones se desprenden de la clasificación. Primero, el flujo individual resulta más invasivo que el global, ya que se observa la transmisión de la fila completa del estudiante (incluyendo correo, historial y nota). Segundo, la pseudonimización de la interfaz coexiste con el envío del identificador real al modelo, por lo que no podría considerarse disociación efectiva.

Sobre datos sensibles: aunque el esquema no los define explícitamente, un campo de texto libre puede contener referencias a salud, situaciones familiares u otras categorías especialmente protegidas. La instrucción del prompt de “no mencionar datos sensibles” opera sobre la respuesta del modelo, no sobre el envío previo del dato.

5. Evaluación por principios

Minimización y calidad. El flujo individual transmite datos que exceden la finalidad declarada (correo, nota docente completa, texto libre sin filtrar). Sería recomendable acotar el conjunto de datos enviados a los indicadores estrictamente necesarios.

Finalidad y transparencia. La llamada al proveedor puede activarse al cargar el panel, sin un aviso explícito al titular. Sería conveniente incorporar una capa de información sobre finalidad, destinatarios y condiciones del tratamiento.

Proporcionalidad y disociación. El plugin conserva identificadores reales en el backend e incluso solicita su devolución por parte del modelo. Una alternativa más sólida podría ser el uso de un identificador efímero local junto con una representación minimizada de los indicadores.

Seguridad y confidencialidad. Se observan varios aspectos a fortalecer: la API key se almacena y muestra en el HTML del modal de configuración; el token sesskey no se verifica del lado servidor; la salida HTTP utiliza cURL crudo en lugar del wrapper nativo de Moodle; y las tablas internas no presentan política de expiración.

Transferencias internacionales. Tanto Uruguay como Argentina restringen la transferencia a jurisdicciones sin nivel adecuado de protección, salvo excepciones, cláusulas tipo u otras garantías. Si se utilizara un proveedor externo, sería recomendable definir explícitamente su rol como encargado del tratamiento, jurisdicción aplicable, contratos correspondientes y región de procesamiento. La opción de gateway institucional o modelo local reduciría sensiblemente esta exposición.

6. Riesgos relevantes identificados

La estimación de impacto y probabilidad es preliminar y se basa exclusivamente en la lectura del código aportado.

Riesgo	Impacto	Probabilidad	Descripción
Escalada de privilegios sobre la configuración global	Alto	Alta	Quien tenga el permiso de gestionar actividades en un curso podría modificar la configuración global del plugin (proveedor, modelo, endpoint y API key) para todo el sitio.
Exposición de la API key	Alto	Alta	La clave del proveedor se almacena como texto plano y se imprime como atributo “value” en el HTML del modal.
Falta de verificación de sesskey (CSRF)	Alto	Media	El frontend envía sesskey, pero el backend no parece verificarlo, lo que podría facilitar ataques CSRF sobre acciones que modifican datos.
SSRF / salida HTTP no gobernada	Alto	Media-Alta	La URL base es configurable y la llamada utiliza cURL crudo, sin allowlist ni el wrapper nativo de Moodle.
Sobretransferencia de datos al LLM	Alto	Alta	El prompt individual incluye la fila completa del estudiante (correo, nota, historial, contexto), excediendo la finalidad declarada.
Envío automático al abrir el panel	Medio-Alto	Alta	El acceso al panel puede disparar la llamada al proveedor sin acción explícita del docente, afectando la transparencia.
Retención sin política definida	Medio-Alto	Alta	Las tablas internas conservan información sin TTL ni purga automática (sólo existe un script manual por

Riesgo	Impacto	Probabilidad	Descripción
			línea de comando).
Dependencia de CDN externo	Medio	Media	La interfaz carga la librería SheetJS desde un CDN externo, introduciendo dependencia de un tercero del lado del navegador.
Ausencia de límites de uso y costo	Medio	Alta	No se observan mecanismos de rate-limiting, topes de tokens ni métricas de consumo.

7. Posibles líneas de mejora

7.1 Ajustes prioritarios para un piloto controlado

- Restringir la modificación de la configuración global del plugin (proveedor, endpoint y API key) a usuarios con permisos a nivel de sitio.
- Reemplazar la llamada HTTP con cURL crudo por el cliente nativo de Moodle, con soporte de proxy y verificación de URL.
- Verificar el token sesskey del lado servidor en todas las acciones que modifiquen datos.
- Minimizar y pseudonimizar el contenido del prompt antes del envío: evitar correo, nota docente completa, texto libre sin depuración o nombres reales.
- Resguardar la API key como secreto del servidor, evitando su impresión en el HTML.
- Definir tiempos de retención y un proceso automático de purga para las tablas de contexto, acciones y caché de IA.
- Implementar una allowlist explícita de endpoints permitidos para el proveedor de IA.

7.2 Ajustes para una implementación institucional futura

- Realizar una evaluación de impacto en protección de datos formal (Decreto 64/020 en Uruguay; buenas prácticas AAIP en Argentina).
- Inscribir o verificar el registro de la base de datos ante URCDP y, en su caso, AAIP.
- Elaborar y publicar una política de privacidad específica del sistema.
- Definir formalmente el rol del proveedor de IA y suscribir contratos o cláusulas tipo de transferencia internacional.
- Evaluar el uso de un gateway institucional o de modelos locales/self-hosted para escenarios sensibles.
- Incorporar métricas de uso y costo, así como mecanismos de auditoría sobre quién genera análisis y bajo qué configuración.
- Realizar pruebas específicas de seguridad sobre permisos, CSRF, SSRF y exposición de secretos.

7.3 Política operativa sugerida para el piloto

- **Modo por defecto:** habilitar únicamente análisis global minimizado (sin nombres, correos, notas ni texto libre).
- **Modo individual:** habilitar sólo para roles autorizados y cuando exista justificación pedagógica concreta.
- **Texto libre:** evitar su envío externo sin un proceso previo de redacción y filtrado.
- **Proveedor:** priorizar gateway institucional o endpoint local durante el piloto.
- **Retención orientativa:** 30 días para caché de IA, 90 para contexto y 180 para acciones, con revisión semestral.

- **Auditoría:** registrar quién generó cada análisis y bajo qué configuración, sin almacenar prompts completos salvo casos excepcionales.

8. Conclusión

El análisis sugiere que UNI+ presenta un diseño funcional con una característica estratégica valiosa: la posibilidad de operar sobre endpoints OpenAI-compatibles, lo que permitiría redirigir las llamadas hacia un gateway institucional o un modelo local. Esta capacidad facilita avanzar hacia una solución más alineada con los principios de protección de datos.

Al mismo tiempo, en el estado actual del código se observan aspectos a fortalecer, principalmente vinculados a minimización del dato transmitido, gestión de permisos, control de la salida HTTP, retención y trazabilidad. Estos aspectos son habituales en sistemas en etapa temprana de desarrollo y resultan abordables con los ajustes propuestos.

Con los ajustes señalados como prioritarios, un piloto cerrado y acotado parecería viable. Un despliegue institucional ampliado requeriría un trabajo conjunto del equipo técnico, las áreas legales y las autoridades académicas, junto con la validación de aspectos como contratos con proveedores, política de privacidad, registro de la base ante URCDP/AAIP, configuración de la infraestructura y región de procesamiento.

Este aporte se ofrece como insumo preliminar para el diálogo del equipo y no reemplaza un dictamen jurídico ni una auditoría técnica formal.